

SecureSupply AI — Supply Chain Security Report

Generated at: 2026-10-07 03:39:22 UTC

Executive Summary

Project Name:	SecureSupply AI Demo Gateway	Overall Risk Level:	Critical
Total Dependencies:	5	Risk Score:	100.0 / 100
Vulnerable Dependencies:	3	Policy Decision:	BLOCK
Attack Indicators:	2	Suspicious Packages:	1

Vulnerability Assessment Findings

Dependency	CVE / OSV ID	Severity	CVSS	Fixed Version
requests	CVE-2023-32681	HIGH	7.5	2.31.0
urllib3	CVE-2023-45803	MEDIUM	6.1	1.26.18
pillow	CVE-2023-4863	CRITICAL	9.8	10.0.1

Security Recommendations & Remediation

Dependency	Action	Target Version	Rationale
requests	UPGRADE	2.31.0	Upgrade requests to version 2.31.0 to mitigate HIGH severity vulnerability (CVE-2023-32681: Unintended leak of Proxy-Authorization header in requests).
urllib3	UPGRADE	1.26.18	Upgrade urllib3 to version 1.26.18 to mitigate MEDIUM severity vulnerability (CVE-2023-45803: urllib3 request body leak on redirect).
pillow	UPGRADE	10.0.1	Upgrade pillow to version 10.0.1 to mitigate CRITICAL severity vulnerability (CVE-2023-4863: Heap-based buffer overflow in WebP in Pillow).
	REMOVE		Immediately remove 'None' due to detected supply chain attack indicator: Package 'flatmap-stream' exhibits maintainer anomaly or hijacked release indicators.
flatmap-stream	REMOVE		Quarantine or remove 'flatmap-stream'. High suspicion score (85.0/100) due to triggers: KNOWN_SUSPICIOUS_PACKAGE: Package flatmap-stream matches known malicious signature database.